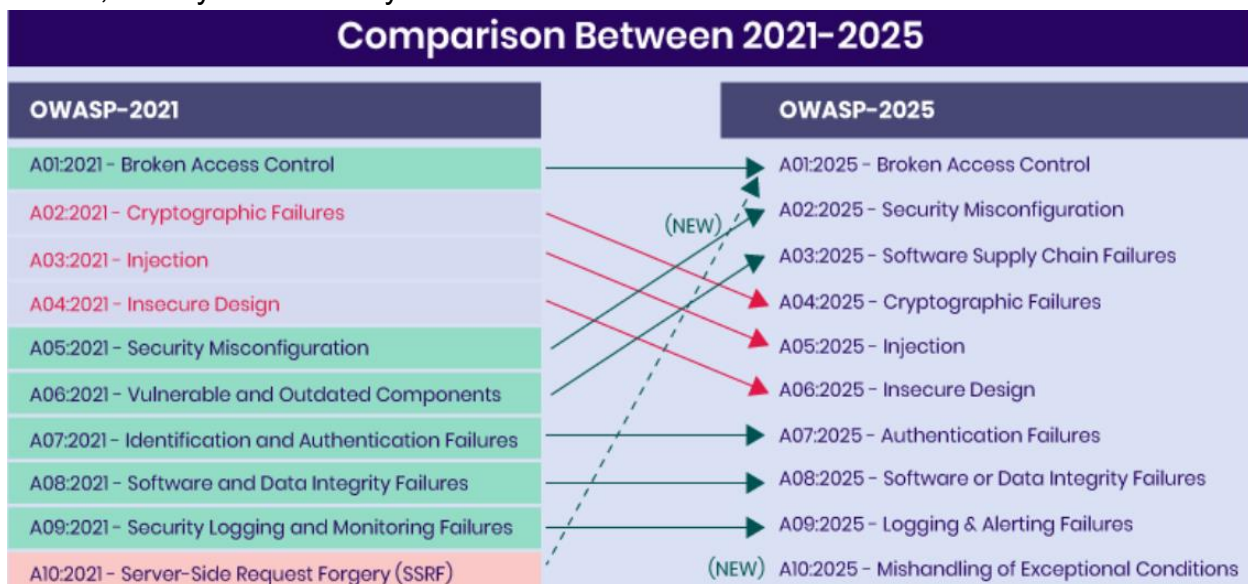


Lab 1: Exploring the OWASP Top 10

1. How has the OWASP Top 10 evolved over the past few years, and what are the key differences in the most recent versions compared to earlier ones?

-OWASP Top 10 has evolved over the years to reflect modern technologies and cyber threats. Earlier versions focused mainly on traditional web vulnerabilities such as SQL Injection and XSS, while newer versions focus more on cloud security, software supply chains, and system security.



-DIFFERENCES BETWEEN OLD VERSION (2021) AND NEW VERSION (2025)

- + **Broken Access Control** remains the #1 risk in both 2021 and 2025 because authorization and permission issues are still the most critical problems in APIs and cloud systems.
- + **Security Misconfiguration** increased from rank #5 to #2 due to the rapid growth of cloud computing, Docker, Kubernetes, and DevOps environments, where many systems are configured incorrectly or use default credentials.
- + **Software Supply Chain Failures** is a new category in 2025 that replaces “Vulnerable and Outdated Components” and focuses on attacks targeting open-source libraries, dependencies, and CI/CD pipelines.
- + **Cryptographic Failures** moved down in ranking because modern encryption technologies are becoming more secure and widely adopted.

- + **Injection** drops from #3 to #5 because modern frameworks and secure coding practices now provide better protection against SQL Injection and XSS.
- + **Insecure Design** remains an important issue but dropped in ranking as OWASP now focuses more on cloud and infrastructure security.
- + **SSRF** is no longer a separate category and is now included in broader cloud and access control issues.
- + **Mishandling of Exceptional Conditions** is a new category about insecure error handling, fail-open situations, and logical failures in systems.

2. What are the common factors that lead to vulnerabilities moving up in rank within the OWASP Top 10 list? Are there specific trends or technologies that contribute to this change?

-Factors:

- + A vulnerability rises in ranking when it becomes more common, more dangerous, or easier for hackers to exploit.
- + Modern systems are becoming more complex, which increases the chances of security vulnerabilities.
- + Modern attack tools also help hackers discover and exploit vulnerabilities more quickly than before.

-Trend and tech:

- + Cloud computing increases the risk of misconfigurations and data exposure.
- + APIs and microservices increase issues related to authorization and user authentication.
- + The use of open-source libraries and third-party packages increases the risk of software supply chain attacks.

3. Can you identify real-world examples of data breaches or security incidents that were caused by vulnerabilities listed in the OWASP Top 10? What were the consequences, and how could these incidents have been prevented?

+ Equifax (SQL Injection):

Equifax was attacked via SQL Injection, exposing data of about 147 million users due to improper input validation and delayed patching. Prevention: use prepared statements, validate inputs, and apply timely security patches.

+ Capital One (SSRF):

Capital One suffered an SSRF attack where hackers accessed AWS metadata service and stole credentials, leading to data exposure of over 100 million customers.

Prevention: block metadata access, enforce IAM least privilege, and restrict outbound requests.

+ Yahoo (Broken Authentication):

Yahoo experienced a breach affecting 3 billion accounts due to weak authentication and poor session management. Prevention: use MFA, strong password hashing, and secure session handling.

+ Target (Broken Access Control):

Target was breached through a third-party vendor, allowing attackers to escalate privileges into the POS system and steal 40 million payment cards. Prevention: zero trust architecture, network segmentation, and strict vendor access control.

4. Are there regional or industry-specific variations in the prevalence of vulnerabilities listed in the OWASP Top 10? How do these variations impact security practices and strategies?

+ Finance and E-commerce: Broken Access Control, Injection, and Authentication issues are more common because systems handle sensitive data and transactions.

+Tech : Security Misconfiguration and SSRF are more frequent due to complex cloud infrastructure and heavy API usage.

+ In regions with lower security maturity: SQL Injection and outdated software are still widely seen because of weak security practices.

+ These differences impact security strategies by making finance focus on access control and authentication, while cloud companies prioritize configuration security and API protection.

5. What are the most effective strategies and best practices for developers and organizations to proactively address and mitigate the vulnerabilities outlined in the OWASP Top 10?

+ Threat modeling: anticipating security risks during the design phase.

+ Access control: RBAC, least privilege, and server-side authorization checks.

+ Secure coding: preventing injection using input validation and parameterized queries.

+ Logging & monitoring: early detection of attacks through logging and system monitoring.

